

AI-Powered Reconnaissance

1. How AI Transforms the Reconnaissance Phase

Reconnaissance has always been the first phase of the attack lifecycle — ATT&CK TA0043 — but it has historically been the bottleneck. A skilled analyst conducting manual open-source intelligence (OSINT) research might thoroughly profile a few targets per day. AI removes this constraint. LLM-orchestrated pipelines can correlate data from dozens of public sources, synthesise unstructured content into structured intelligence, and prioritise attack vectors — all in hours rather than days.

The qualitative shift is not simply speed. AI enables three capabilities that manual reconnaissance cannot match: systematic correlation across disparate sources (finding that a LinkedIn skill endorsement and a job posting together reveal a specific firewall model and software version), inference from indirect signals (job postings as technology stack indicators), and scale without proportional cost increase. Understanding these capabilities informs both offensive simulation and defensive posture.

2. The AI-Enhanced OSINT Tool Ecosystem

The OSINT tool landscape has evolved rapidly. Traditional aggregation tools (Maltego, Shodan, Recon-ng, SpiderFoot) were already capable of broad data collection; AI layers add correlation, natural language synthesis, and prioritisation on top.

Tool / Platform	Primary Function	AI Enhancement	Attacker / Defender Use
Shodan	Internet-connected device scanning	MCP server integration (2024-25) enables AI agent querying for vulnerable devices by org IP range	Both — asset discovery and attack surface exposure
VirusTotal	File and URL reputation	MCP server integration enables AI-driven bulk analysis and correlation	Both — malware analysis and attacker infrastructure profiling
SpiderFoot HX	Multi-source OSINT aggregation	LLM-based natural language attack surface summaries from collected data	Both — automated org profiling
Maltego	Graph-based link analysis	Community transforms correlate entities across breach data, social networks, domain registrations	Both — relationship mapping
GitLeaks / TruffleHog	Git repository secret scanning	AI-enhanced versions correlate discovered secrets across repositories and assess current validity	Both — credential exposure detection
OSINT Framework + LLM	Guided OSINT collection	LLM synthesises findings into prioritised attack surface reports	Red teams — realistic attack vector ranking

3. LLMs as Intelligence Analysts: What They Do Better Than Humans

LLMs bring specific capabilities to OSINT analysis that complement data aggregation tools:

- **Unstructured-to-structured synthesis:** An LLM can read a company's website, employee LinkedIn profiles, job postings, GitHub repositories, and press releases — all unstructured text — and produce a structured profile: technology stack, org hierarchy, named decision-makers, inferred security posture.
- **Indirect signal inference:** A job posting for 'Senior Engineer, Palo Alto Networks PA-5400 series administration' reveals firewall vendor and model. A requirement for 'AWS GuardDuty and CloudTrail expertise' reveals cloud security tooling. LLMs parse these signals systematically at scale.
- **Cross-source correlation:** Human analysts see one source at a time; LLMs correlate across all sources simultaneously. A Shodan result for an exposed service + a LinkedIn profile showing the admin's skill set + a GitHub commit showing a configuration file reference = a prioritised attack path.
- **Natural language querying:** Analysts can ask 'What is the most likely initial access vector for an attacker targeting this organisation, based on public information?' and receive a synthesised, prioritised answer — not raw data requiring interpretation.

Real-World Scenario — AI-Orchestrated Pre-Attack Profiling of Healthcare Network (2024): A threat actor targeting a healthcare network deployed an LLM-orchestrated reconnaissance pipeline that queried Shodan for assets in the organisation's IP ranges (finding unpatched Citrix Gateway appliances), processed LinkedIn to map IT department headcount and skills (identifying a three-analyst security team), scraped GitHub for public repositories containing internal API references and hardcoded credentials, and processed job postings to infer the security tool stack. The attacker had a comprehensive attack plan — including the specific Citrix CVE to exploit, the understaffed security team response capacity, and valid API credentials — before making a single connection to the target environment.

4. Social Graph Mapping at Scale

Beyond technical reconnaissance, AI enables sophisticated social graph mapping — understanding not just who works at an organisation but the relationships between individuals that enable targeted social engineering. Inputs include LinkedIn profile data, email pattern inference, cross-referencing against breach databases, and social media activity.

The output is an attack-relevant relationship map: reporting hierarchies (who controls budget and payment authorisations), personal connections (shared university, mutual contacts, former employers), and communication patterns (who regularly emails whom). Practical application: knowing that the CFO and a specific vendor contact attended the same university enables a pretexting scenario rooted in a fabricated shared connection — a pretext far more convincing than a generic authority impersonation. AI processes this social graph data across multiple platforms simultaneously at a scale that makes targeted social engineering operationally practical even against mid-level employees.

5. GitHub and Code Repository Exposure: The Persistent Credential Risk

Public GitHub repositories are among the richest sources of attack-relevant intelligence. The challenge organisations face is that credential exposure in git history is permanent unless the credentials are actively revoked — removing a file from the current branch does not purge it from the commit history, which remains fully accessible.

- A 2024 research study of Fortune 500 GitHub organisations found that 23% had at least one repository with a committed AWS or Azure credential in its history.
- GitLeaks and TruffleHog scan repositories for secrets; AI-enhanced versions correlate discovered secrets across repositories to assess scope and current validity.
- Internal endpoint references, database connection strings, and hardcoded API keys in configuration files provide a roadmap of internal architecture even without valid credentials.
- Git history scanning covers not just the current HEAD but all historical commits — a credential committed and deleted three years ago is still discoverable.
- Mitigation: pre-commit hooks that scan for secrets before they reach the remote; GitHub secret scanning (built-in); BFG Repo Cleaner to purge historical secrets combined with immediate credential rotation.

6. Supply Chain Reconnaissance: Attacking Through Trusted Third Parties

SolarWinds (2020) and MOVEit (2023) demonstrated that attacking a well-defended organisation is sometimes most efficiently accomplished by first compromising a less-defended vendor with privileged access. AI-enhanced reconnaissance makes systematic supply chain mapping practical.

The process: query vendor directory listings and procurement databases for third parties with contractual access to the target; correlate job postings (vendors advertising for 'experience with client X environment'); review security certifications (vendors advertising SOC 2 or FedRAMP certifications that imply client access); cross-reference with breach databases (has the vendor previously been breached, and were credentials recovered?). The result is a ranked list of supply chain attack paths ordered by likely attacker return on investment. Organisations conducting supply chain risk assessments should apply the same AI-enhanced mapping to their own vendor inventory.

Exam Principle — OSINT Hygiene as a Proactive Security Control: Information minimisation — limiting what must be public and auditing what has inadvertently become public — raises the attacker's cost and slows their timeline even when it cannot eliminate the OSINT attack surface entirely. Job postings that specify exact tool versions, LinkedIn profiles that enumerate security tool skill endorsements, and GitHub repositories with commit histories containing internal references all represent controllable information exposure. The security team's collaboration with HR and legal to establish OSINT hygiene policies is a legitimate, measurable security control — not just an awareness initiative.

7. Technical Reconnaissance: AI-Enhanced Vulnerability Discovery

AI accelerates the technical side of reconnaissance — identifying vulnerable assets within a target's attack surface. The workflow combines passive data sources with AI-driven prioritisation:

- **Shodan / Censys:** Internet-wide scanning data identifies assets in the target's IP ranges, operating systems, open ports, and service banners indicating software versions.
- **CVE correlation:** AI systems correlate discovered software versions against the CVE database to identify unpatched vulnerabilities, ranked by CVSS score and availability of public exploit code.
- **LLM-assisted exploit reasoning:** GPT-4 and similar models have demonstrated ability to reason about CVE descriptions and generate conceptual exploit approaches when presented with vulnerable code — accelerating the gap between CVE publication and weaponisation.
- **Prioritisation:** AI determines which combination of discovered vulnerabilities represents the highest-value attack path given the attacker's stated objective — e.g., 'highest likelihood path to domain controller credentials'.

8. Detecting Active Reconnaissance

Organisations can detect active reconnaissance before an attack launches. Detection mechanisms work across multiple channels:

Detection Mechanism	What It Detects	Implementation
WAF / web server log analysis	Scanning patterns — rapid requests across parameter ranges, probing non-existent endpoints, account enumeration	Pattern matching and rate limiting rules in WAF; SIEM alerting on access log anomalies
Honeytokens	Access to fake credentials, fake URLs, or fake API endpoints embedded in documentation	Canary tokens (canarytokens.org) embedded in various document types; dedicated honeytoken infrastructure
Email domain monitoring	DNS queries for SPF/DKIM/DMARC records — often a precursor to phishing infrastructure setup	DNS query logging with SIEM alerts on unusual external SPF/DMARC lookups for org domains
Canary documents	Alerts when reconnaissance tools or analysts open embedded canary documents during phishing pre-work	Canarytokens.org embedded in public documents, templates, shared drives
Darknet monitoring	Employee lists, technology inventories, or credentials being traded in criminal forums	Commercial darknet monitoring services (Recorded Future, Mandiant Advantage)

9. Red Team Application: AI-Assisted Passive Reconnaissance

Red teams use AI-enhanced reconnaissance to scope engagements more realistically and demonstrate the actual information available to a patient, skilled attacker. The most valuable finding a red team can

deliver from this phase is not a list of vulnerabilities — it is the specificity of what an attacker can determine about an organisation before making first contact.

Practical red team workflow: use LLM-orchestrated OSINT tools to build the attack surface profile (technology stack, key personnel, supply chain relationships, credential exposure in public repos), then ask the LLM: 'Rank the most likely initial access paths for a financially motivated threat actor targeting this organisation.' Present the resulting ranked list to the client as a risk prioritisation input.

Organisations are often unaware of how detailed a profile an attacker can assemble, and this demonstration creates urgency for OSINT hygiene improvements.

10. Proactive Threat Intelligence to Anticipate Reconnaissance

Threat intelligence provides early warning of reconnaissance activity targeting an organisation or its sector before an attack is launched:

- **ISACs (Information Sharing and Analysis Centres):** Sector-specific sharing organisations distribute reconnaissance patterns targeting peer organisations — allowing members to harden before attack.
- **Commercial threat intelligence (Recorded Future, Mandiant Advantage):** Track known threat actor reconnaissance activity, including targeting signals and infrastructure preparation.
- **Darknet monitoring:** Identify when organisational data — employee directories, network diagrams, technology inventories — appears in criminal forums, a frequent precursor to targeted attacks.
- **DNS monitoring:** Monitor for newly registered domains that typosquat or impersonate the organisation's domains — often registered during the reconnaissance phase in preparation for phishing infrastructure.

11. Legal and Ethical Boundaries of AI-Enhanced Reconnaissance

The same AI reconnaissance tools used by attackers are also used by legitimate security researchers, competitive intelligence analysts, and journalists. The legal boundary is drawn by authorisation and intent:

- OSINT from genuinely public sources is generally legal in most jurisdictions.
- Automated mass collection from platforms that prohibit it (via terms of service) creates civil liability — LinkedIn's ToS explicitly prohibits scraping.
- Accessing private systems or data without authorisation violates the Computer Fraud and Abuse Act (CFAA) in the US and the Computer Misuse Act (CMA) in the UK.
- Collecting EU personal data as part of reconnaissance activities may trigger GDPR obligations.
- SecAI+ practitioners conducting AI-enhanced reconnaissance on behalf of their organisations must operate under written authorisation, document scope, and comply with applicable laws.

MITRE ATLAS reconnaissance techniques differ from ATT&CK TA0043 in an exam-relevant way: ATLAS focuses on reconnaissance against ML system components specifically — model architecture discovery, training data inference, API query patterns to identify model type. Both are testable on the SecAI+ exam. Know the distinction: standard OSINT-focused recon targets organisational infrastructure; ML-targeted recon targets the AI/ML components themselves.

Key Terms Glossary

Term	Definition
OSINT (Open-Source Intelligence)	Intelligence gathered from publicly available sources — websites, social media, job postings, domain records, code repositories, and internet scanning data.
ATT&CK TA0043	The MITRE ATT&CK Reconnaissance tactic — the first phase of the attack lifecycle covering information gathering before initial access.
Shodan	An internet-connected device search engine that indexes service banners, enabling discovery of vulnerable devices by IP range, organisation, or software version.
Model Context Protocol (MCP)	A protocol enabling AI agents to query external tools and data sources programmatically — used by Shodan and VirusTotal to expose data to AI orchestrators.
SpiderFoot HX	A multi-source OSINT aggregation tool with LLM-based natural language attack surface summary generation.
GitLeaks / TruffleHog	Tools that scan git repository histories for committed secrets (API keys, credentials, connection strings).
Social graph mapping	Analysing relationships between individuals in an organisation to identify high-value targets and social engineering pretexts.
Honeytokens	Fake credentials, URLs, or document tokens that trigger alerts when accessed — used to detect reconnaissance activity.
Canary tokens	Tracking tokens embedded in documents, URLs, or data that alert when accessed, providing early warning of reconnaissance.
ISAC (Information Sharing and Analysis Centre)	A sector-specific organisation that shares threat intelligence among member organisations — ISACs exist for financial services, healthcare, energy, and others.
OSINT hygiene	Organisational policies and practices that limit unnecessary public information exposure to increase attacker reconnaissance cost.
Supply chain reconnaissance	Reconnaissance targeting not the primary victim but their suppliers and vendors with privileged access to the target environment.

Quick Revision Checklist

- AI transforms reconnaissance from a manual bottleneck to an automated, scalable capability — hours instead of days, hundreds of targets instead of a few.
- LLMs synthesise unstructured public data (job postings, LinkedIn, GitHub, websites) into structured intelligence and prioritised attack paths.
- Job postings are a major OSINT signal — they reveal specific tool versions, vendor relationships, and security team size/skill.
- Social graph mapping uses AI to correlate relationships across platforms, enabling highly personalised social engineering pretexts.
- GitHub commit history permanently records secrets even after file deletion — 23% of Fortune 500 GitHub organisations had at least one repository with committed cloud credentials.

- Supply chain reconnaissance (SolarWinds model) maps third-party vendors with privileged target access — AI makes this systematic rather than opportunistic.
- OSINT hygiene — controlling public information — is a proactive security control: job posting content policy, LinkedIn visibility settings for sensitive roles, private repositories.
- Honeytokens and canary documents provide reconnaissance detection before attack launch.
- MITRE ATLAS reconnaissance targets ML system components (model architecture, training data); ATT&CK TA0043 targets organisational infrastructure — both are SecAI+ exam topics.
- Legal boundary: public OSINT is generally legal; ToS-prohibited scraping creates civil liability; unauthorised system access violates CFAA/CMA; EU personal data collection may trigger GDPR.
- Shodan MCP and VirusTotal MCP server integrations (2024-25) enable AI agents to query internet scanning and threat intelligence data directly.
- Proactive threat intelligence (ISACs, commercial feeds, darknet monitoring) provides early warning of reconnaissance activity before attack launch.

10 Exam-Based MCQs — AI-Powered Reconnaissance

Test yourself after reading. These questions are written in exam style — scenario-heavy with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: An LLM-orchestrated reconnaissance pipeline targeting a healthcare organisation processes Shodan scanning data, LinkedIn profiles, GitHub repositories, and job postings. The pipeline produces a synthesised attack surface report. Which finding from the AI-orchestrated reconnaissance pipeline represents the HIGHEST-VALUE intelligence for the attacker's initial access planning?

- A) The organisation's public website lists three office locations
- B) Shodan identifies unpatched Citrix Gateway appliances on the network perimeter
- C) LinkedIn shows the CISO has 2,400 connections
- D) The organisation's domain has been registered for twelve years

Answer: B **Explanation:** B is correct because unpatched Citrix Gateway appliances on the network perimeter represent a direct, actionable initial access path — a specific vulnerability on an internet-facing system that can be exploited. Citrix Gateway vulnerabilities (e.g., CVE-2023-3519, CVE-2023-4966) have known public exploits and are actively targeted. A is wrong — office location information is useful for physical reconnaissance but does not provide a technical initial access path. C is wrong — CISO connection count is not actionable intelligence for initial access; it might inform social engineering but is significantly less valuable than a directly exploitable vulnerability. D is wrong — domain registration age provides no actionable attack-planning intelligence.

Q2. A job posting for 'Senior Network Security Engineer — Expertise in Palo Alto PA-5400 Series and Fortinet FortiGate 600F required' reveals which type of intelligence?

- A) Social graph mapping data
- B) Technology stack disclosure through indirect OSINT signals
- C) Credential exposure through public data sources
- D) Supply chain reconnaissance findings

Answer: B **Explanation:** B is correct. Job postings that list specific vendor product model numbers disclose the organisation's deployed technology stack — in this case, the specific firewall models and therefore the attack surface for known CVEs against those products. This is a primary example of indirect OSINT signal inference, a core capability AI brings to reconnaissance. A is wrong — social graph mapping concerns relationships between individuals, not technology asset data. C is wrong — credential exposure refers to committed secrets in repositories or breach data, not job posting content. D is wrong — supply chain reconnaissance maps third-party vendors with privileged access, not the organisation's own technology stack.

Q3. Scenario: An attacker is using an LLM to systematically analyse a target organisation's job postings to infer which security tools are deployed, then cross-referencing with CVE databases to identify unpatched vulnerabilities in those specific products. Which control would MOST effectively reduce the organisation's exposure to this reconnaissance approach?

- A) Implement MFA on all employee accounts
- B) Establish job posting content policies that avoid specifying exact vendor product versions and security tool names
- C) Deploy a SIEM to monitor internal network traffic
- D) Require all employees to use VPN when working remotely

Answer: B **Explanation:** B is correct because the attack relies on information disclosed in job postings to identify specific security tools and product versions in use. Establishing a content policy that avoids specifying exact vendor product names and versions in postings directly addresses the source of the intelligence the attacker is exploiting. This is OSINT hygiene applied to a specific channel. A is wrong — MFA protects against credential compromise but does not reduce the information disclosed in job postings. C is wrong — a SIEM monitors internal network traffic; it does not address the OSINT attack surface created by public job postings. D is wrong — VPN protects remote access sessions but does not affect what information is disclosed publicly.

Q4. What is the PRIMARY reason that AI-enhanced social graph mapping increases the effectiveness of targeted social engineering compared to manual methods?

- A) AI generates more grammatically correct pretexting messages
- B) AI correlates relationship data across multiple platforms simultaneously, enabling highly personalised pretexts at scale
- C) AI accesses private social media profiles that manual researchers cannot
- D) AI generates synthetic identities with verifiable work histories

Answer: B **Explanation:** B is correct. The key advantage of AI-enhanced social graph mapping is the ability to correlate data across multiple platforms (LinkedIn, email patterns, breach databases, GitHub, Twitter/X) simultaneously and at scale — finding shared connections, common interests, and relationship patterns that enable highly specific and convincing pretexts. Manual analysts can do this for a small number of targets; AI can do it for thousands simultaneously. A is wrong — grammar quality is a real but secondary advantage; the primary advantage is scale and depth of correlation. C is wrong — AI cannot access private profiles that are not publicly accessible; OSINT techniques are constrained to public data. D

is wrong — while AI can assist in creating synthetic personas, that is a separate attack capability distinct from the reconnaissance phase of social graph mapping.

Q5. A security team discovers that a developer committed an AWS access key to a public GitHub repository three years ago and then deleted the file in the next commit. What is the CORRECT assessment of the current risk?

- A) The risk is eliminated because the file was deleted from the repository
- B) The risk remains because git history retains the committed file and the key may still be valid
- C) The risk is low because automated scanners would have detected it at time of commit
- D) The risk is eliminated because AWS automatically rotates keys that appear in public repositories

Answer: B **Explanation:** B is correct. Git history is permanent — removing a file from the current branch does not purge it from the commit history. Tools like GitLeaks and TruffleHog specifically scan full git history, not just the current HEAD. If the key has not been explicitly revoked and a new key issued, it may still be valid. A is wrong — deleting the file from the current branch does not remove it from git history; the commit is still accessible. C is wrong — automated scanners such as GitHub secret scanning were not always available and are not retroactive across historical commits in all configurations; the assumption that detection occurred cannot be made. D is wrong — AWS does not automatically rotate or revoke keys that appear in public repositories in real time; this is the responsibility of the key owner.

Q6. Which MITRE framework covers reconnaissance techniques specifically targeting ML system components, such as model architecture discovery and training data inference?

- A) MITRE ATT&CK TA0043
- B) MITRE ATLAS v2.1
- C) NIST AI RMF 1.0 MAP function
- D) OWASP LLM Top 10

Answer: B **Explanation:** B is correct. MITRE ATLAS v2.1 covers adversarial techniques targeting AI/ML systems specifically, including ML-targeted reconnaissance techniques such as model architecture discovery (identifying model type from API response patterns), training data inference (model inversion), and API querying to understand decision boundaries. A is wrong — ATT&CK TA0043 covers reconnaissance against organisational infrastructure (websites, DNS, employee profiles, etc.) but does not cover ML-specific reconnaissance techniques. C is wrong — NIST AI RMF MAP function covers AI risk identification in a governance context; it is not a threat taxonomy. D is wrong — OWASP LLM Top 10 addresses risks specific to large language model applications, not a general adversarial ML taxonomy.

Q7. A security team wants early warning that a threat actor may be preparing to launch a phishing campaign against the organisation. Which detection control is MOST likely to provide advance notice?

- A) Email DMARC enforcement
- B) DNS monitoring for newly registered domains that typosquat the organisation's domain
- C) Web application firewall rules detecting SQL injection attempts

D) Endpoint detection and response (EDR) behavioural monitoring

Answer: B **Explanation:** B is correct. Attackers preparing phishing campaigns typically register typosquatting or lookalike domains during the reconnaissance/resource development phase — before launching the attack. Monitoring for newly registered domains that resemble the organisation's domain (e.g., corp0rate-bank.com for corporate-bank.com) provides advance warning before phishing emails are sent. A is wrong — DMARC enforcement prevents spoofing of the organisation's exact domain in email but does not detect lookalike domains registered by the attacker; it operates at delivery time, not during reconnaissance. C is wrong — SQL injection detection identifies web application attacks, not phishing campaign preparation. D is wrong — EDR monitors endpoint execution behaviour, which would only be triggered after the attack has already resulted in a compromised endpoint.

Q8. An employee receives an email appearing to come from a colleague referencing a shared university connection. The email asks them to review a contract attachment. Which type of AI-enhanced attack does this MOST likely represent?

- A) A generic phishing campaign using AI for grammar correction
- B) A spear phishing attack enabled by AI social graph mapping to identify and exploit a personal connection
- C) A supply chain attack targeting the organisation through the university relationship
- D) A data poisoning attack using the employee's email behaviour patterns

Answer: B **Explanation:** B is correct. Using a personal connection (shared university) as a spear phishing pretext requires knowledge of the relationship between the employee and the sender — information that AI social graph mapping can derive by correlating LinkedIn education history across multiple individuals. The result is a highly personalised and convincing pretext that goes far beyond generic phishing. A is wrong — the specificity of the shared university reference indicates targeted spear phishing, not a generic campaign; grammar correction is not the distinguishing AI-enhanced capability here. C is wrong — the attack targets the employee directly through a social engineering pretext; a supply chain attack would involve compromising a third-party vendor. D is wrong — data poisoning targets ML model training data, not email-based social engineering.

Q9. Which legal instrument governs the prohibition on unauthorised automated access to computer systems during AI-enhanced reconnaissance in the United States?

- A) GDPR Article 32
- B) Computer Fraud and Abuse Act (CFAA)
- C) NIST SP 800-115
- D) ISO/IEC 42001:2023

Answer: B **Explanation:** B is correct. The Computer Fraud and Abuse Act (CFAA) is the primary US federal statute governing unauthorised access to computer systems. Accessing private systems or data without authorisation during reconnaissance violates the CFAA regardless of whether the access is AI-assisted or manual. A is wrong — GDPR Article 32 addresses security of personal data processing in the EU; it is relevant when EU personal data is collected during reconnaissance but does not directly prohibit unauthorised system access in the US. C is wrong — NIST SP 800-115 is a technical guide for information

security testing; it is a guidance document, not a legal instrument. D is wrong — ISO/IEC 42001:2023 is an AI management system standard; it is a governance framework, not a legal prohibition.

Q10. Which combination of controls provides the BEST layered defence against AI-powered reconnaissance?

- A) OSINT hygiene policies, honeypot deployment, and proactive threat intelligence
- B) Network segmentation, IDS signatures, and full disk encryption
- C) MFA enforcement, VPN requirements, and SIEM deployment
- D) Penetration testing, vulnerability scanning, and patch management

Answer: A **Explanation:** A is correct because it addresses the reconnaissance threat at three layers: OSINT hygiene (reduces the information available to attackers by controlling public exposure), honeypots (detects active reconnaissance before attack launch by triggering alerts when accessed), and proactive threat intelligence (anticipates reconnaissance activity through industry sharing and darknet monitoring). Together these reduce attacker efficiency, provide early warning, and enable proactive hardening. B is wrong — network segmentation, IDS, and disk encryption are post-exploitation controls that operate after initial access; they do not address the reconnaissance phase. C is wrong — MFA, VPN, and SIEM protect access and monitor internal activity; they do not reduce the OSINT attack surface or detect pre-attack reconnaissance. D is wrong — pen testing, scanning, and patching address technical vulnerabilities post-discovery; they do not specifically address the AI-enhanced reconnaissance threat model.